EXCEPTION MANAGEMENT POLICY AND REGISTER

EXC-001 | Governance-Level Companion Document | Information Management Framework

Document ID: EXC-001
Version: 1.0 — DRAFT
Parent Framework: IMF-001 — Information Management Framework
Classification: Internal Use
Owner: Chief Information Security Officer
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Exception Management Policy and Register
Document ID	EXC-001
Version	1.0 — DRAFT
Status	Draft for Review
Document Type	Governance-level companion document — sits at the same level as IMF-001, RACI-001, and REG-001. Applies across all IMF policies simultaneously.
Parent Framework	IMF-001 — Information Management Framework
Document Owner	Chief Information Security Officer (CISO)
Custodian	Information Security
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	ISO/IEC 27001:2022 (A.5.36); 21 CFR Part 11; EU Annex 11; SOX; GDPR Art. 5(2) (accountability); ICH Q10 (CAPA)

NOTE: This document contains both the policy (Sections 1–9) and the live Exception Register (Section 10). The Register is a controlled document — entries must be made and closed by authorised individuals only. Unauthorised entries are a governance failure. All entries are subject to ISSG review at each quarterly meeting.

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This document establishes [Company Name]'s policy for managing exceptions to the requirements of the Information Management Framework — the body of policies, SOPs, and standards issued under IMF-001. An exception is a formal, time-bounded, risk-assessed, and approved deviation from a mandatory requirement of any IMF policy.

Exceptions exist because the real world is not perfectly accommodated by policy. A legacy system may be technically incapable of meeting a new control requirement before a remediation project is complete. A business-critical process may require a temporary deviation during a transition period. A third-party constraint may make immediate compliance impossible. In each case, the organisation faces a choice: operate with an undocumented, uncontrolled deviation — an invisible risk — or operate with a documented, approved, compensating-controlled, time-bounded exception — a managed risk.

This policy mandates the latter. An undocumented deviation from an IMF policy requirement is not an exception — it is a non-compliance. Non-compliance is a disciplinary matter; an approved exception is a managed risk with a clear remediation path. The distinction matters to regulators, auditors, and the organisation's own governance programme.

> **IMPORTANT:** An exception approved under this policy does not reduce [Company Name]'s regulatory obligations. GDPR, GxP regulations, SOX, and HIPAA do not provide for internal exception processes. An exception to an IMF policy requirement that reflects a regulatory obligation means [Company Name] is operating with a known regulatory gap — this must be reflected in the risk assessment, and the remediation timeline must be aggressive. Certain exception types described in Section 5 are close to non-approvable for this reason.

2. Scope

This policy applies to all exceptions to requirements of IMF-governed documents — specifically:

- All numbered policies (POL-001 through POL-015) and their SOPs
- All requirements specified in companion governance documents (IMF-001, RACI-001, REG-001)

The following are explicitly outside scope and are not managed as exceptions under this policy:

- Deviations from non-mandatory guidance or recommendations within IMF documents — these do not require exception approval
- Changes to policy requirements — a requirement that is genuinely wrong or no longer appropriate should be amended via the IMF document review process under IMF-001, not worked around via exceptions

- GxP deviations from validated system configurations or batch record requirements — these are governed by the quality management system CAPA process, not this policy; they may additionally require an IMF exception if an information management policy is also implicated
- Planned maintenance or scheduled downtime approved under POL-007 — these are not exceptions to availability requirements; they are approved operational events

3. Exception Categories

Exceptions are categorised by the IMF policy domain they relate to. The category determines the minimum approval authority, the maximum permitted duration, and the involvement of specialist reviewers. Where a single exception implicates multiple policy domains, the most restrictive requirements apply.

Category	Implicated Policies	Specialist Reviewer Required	Max Duration	Notes
Data Classification & Handling	POL-001, POL-002	Information Security	12 months	Exceptions to data retention periods require Legal review where statutory retention obligations are implicated.
Data Integrity (GxP)	POL-003, SOP-003	Compliance / QA (mandatory). DIO (mandatory).	6 months	Exceptions in this category directly implicate ALCOA+ regulatory compliance. ISSG notification required for all approved exceptions. See Section 5 — certain data integrity exceptions are non-approvable.
Privacy	POL-004, SOP-004	DPO (mandatory for any exception affecting personal data processing)	6 months	Exceptions that result in personal data being processed without an adequate legal basis are non-approvable. DPO must assess whether GDPR supervisory authority notification is required.
System Classification & Validation	POL-005, SOP-005, POL-006	Compliance / QA (mandatory for GxP systems).	6 months (GxP); 12 months	Exceptions to validation requirements for GxP systems must

Category	Implicated Policies	Specialist Reviewer Required	Max Duration	Notes
		Information Security.	(non-GxP)	be entered in the VMF. Compliance / QA must assess whether the exception creates a non-compliant validated state.
Change Management	POL-007	Information Security. Compliance / QA (GxP systems).	3 months	Short maximum duration — change management exceptions tend to normalise undisciplined practice if left open. Exceptions enabling uncontrolled changes to GxP systems are non-approvable.
Access Control & Privileged Access	POL-008, POL-009	Information Security (mandatory). CISO for Tier 1 / GxP systems.	3 months	Short maximum duration — excessive access exceptions create accumulating risk. Exceptions enabling shared accounts on GxP systems (ALCOA+ Attributable violation) are non-approvable.
Information Security Risk	POL-010	Information Security (mandatory). CISO.	12 months	Risk acceptance under POL-010 is the normal mechanism for residual risks — this is distinct from an exception. An exception here means a procedural requirement of the risk management process cannot be followed.
Business Continuity & DR	POL-011	Information Security. CIO.	6 months	Exceptions to RTO/RPO targets must be compensated by enhanced monitoring and manual workaround procedures.
Incident Response	POL-012, POL-015	Information Security (mandatory). CISO.	3 months	Exceptions to incident notification SLAs require Board awareness if they affect regulatory

Category	Implicated Policies	Specialist Reviewer Required	Max Duration	Notes
				breach notification capability.
Third Party & Vendor	POL-013	Information Security. Legal. DPO (if personal data involved).	6 months	Exceptions allowing vendor access before full assessment completion are high-risk and require CISO approval plus enhanced monitoring as a compensating control.
Audit Trail & Monitoring	POL-014	CISO (mandatory). DIO (mandatory for GxP systems).	3 months	The most restricted category. See Section 5 — exceptions to audit trail immutability and the requirement that audit trails cannot be disabled are non-approvable. Any approved exception requires immediate ISSG notification and Board awareness.

4. Risk Assessment and Approval Authority

Every exception request must include a risk assessment using the same 5×5 likelihood × impact matrix as POL-010, SOP-003 (DIRA), and SOP-004 (DPIA). This ensures residual risk from exceptions is directly comparable to other IS risks in the organisational risk register.

4.1 Risk Scoring

Score	Likelihood	Impact Description
1	Rare — less than once in 5 years	Negligible: no regulatory, financial, or reputational consequence
2	Unlikely — once in 2–5 years	Minor: limited consequence, containable without external notification
3	Possible — once per year	Moderate: material but manageable consequence; possible regulatory notification
4	Likely — several times per year	Significant: regulatory finding, financial loss, or reputational damage likely
5	Almost certain — monthly or more	Severe: critical regulatory finding, major financial loss, or significant reputational damage

Exception risk score = Likelihood × Impact. The score determines approval authority and mandatory compensating controls. The requester provides the initial assessment; Information Security reviews and may revise it.

4.2 Approval Authority Matrix

Risk Score	Risk Level	Approval Authority	ISSG Notification	Board Notification
1–4	Low	Information Security Manager	Not required	Not required
5–9	Medium	CISO	At next quarterly ISSG meeting	Not required
10–14	High	CISO + CIO + Compliance / QA (GxP) or DPO (privacy) or CFO (SOX ITGC) as applicable	Within 5 business days of approval	If exception remains open > 6 months
15–25	Critical	CISO + CIO + CEO + applicable specialist reviewer	Within 2 business days	Required — within 5 business days of approval

IMPORTANT: Critical-scored exceptions (15–25) are approved in name only — they are formal acknowledgements that a serious unmitigated risk exists, with a commitment to remediate it urgently. Approval of a Critical exception does not constitute acceptance that this risk level is tolerable indefinitely. The remediation plan must have executive sponsorship and a target date within the exception duration.

5. Non-Approvable Exceptions

Certain deviations cannot be approved as exceptions under any circumstances because they would create regulatory non-compliance that [Company Name] cannot manage through compensating controls. These are not refusals based on risk appetite — they are absolute limits reflecting hard regulatory requirements.

Non-Approvable Deviation	Governing Requirement	Rationale
Disabling or technically allowing modification of audit trail records on a GxP system	POL-014 Section 4; 21 CFR Part 11 §11.10(e); EU Annex 11 §9	A GxP system whose audit trail can be altered or disabled is not operating in a validated state under 21 CFR Part 11 or EU Annex 11. No compensating control substitutes for audit trail immutability in a regulated context. This is a Critical regulatory finding regardless of whether the capability has been exploited.
Use of shared or generic accounts for GxP data entry or modification	POL-008 Section 4; POL-003 Section 3 (ALCOA+ Attributable); Part 11 §11.10(d)	Records created or modified under a shared account are not attributable to an individual — this is a fundamental ALCOA+ failure. Shared accounts for GxP activities are a regulatory non-compliance, not a compensable risk. Individual named accounts with individual credentials are a non-negotiable regulatory requirement.
Processing of personal data without a valid legal basis	POL-004; GDPR Art. 6, 9	There is no internal exception process for GDPR legal basis. Processing without a legal basis is unlawful. The correct action is to cease the processing or establish a valid legal basis, not to document the unlawful processing as an approved exception.
Transfer of personal data to a third country without an adequate transfer mechanism	POL-013 Section 8; GDPR Art. 44–49	International transfers without an adequacy decision or valid transfer mechanism are unlawful under GDPR. An exception process does not create a transfer mechanism.
Operating a GxP computer system that has never been validated	POL-006; EU Annex 11 §4; 21 CFR Part 11	An unvalidated computer system used for GxP activities is non-compliant regardless of any internal exception approval. If a

Non-Approvable Deviation	Governing Requirement	Rationale
		system cannot be validated before use, it cannot be used for GxP regulated activities. A roadmap to validation does not substitute for validation itself.
Disabling change management controls on a GxP system	POL-007; EU Annex 11 §10	An exception to the requirement for controlled changes on a GxP system would permit uncontrolled changes — immediately placing the system outside its validated state and into regulatory non-compliance.

Where a deviation that would be non-approvable as an exception already exists — for example, a legacy system found to have a modifiable audit trail — this must be treated as an open finding in the IS Risk Register (POL-010) with a mandatory remediation plan and timeline, not documented as an exception. The existence of such a finding must be escalated to ISSG and, for GxP systems, to Compliance / QA for assessment of regulatory notification obligations.

6. Exception Lifecycle

Every exception follows a defined lifecycle from request through to closure. No stage may be skipped. Exceptions that are not actively managed — not reviewed, not renewed, not closed — automatically lapse and the underlying deviation becomes non-compliance.

Step 01	**Exception Request** The Requester (the System Owner, process owner, or team lead responsible for the area where the deviation exists) submits an Exception Request covering: (1) the specific policy requirement being deviated from, with the document ID and section; (2) the nature of the deviation — what is not being met and why; (3) the business or technical reason the requirement cannot currently be met; (4) the proposed compensating controls; (5) the proposed exception duration; (6) the proposed remediation plan — the steps and timeline to achieve full compliance. Exception requests are submitted to Information Security via the designated exception management channel. A request that does not include all required fields is returned to the requester without assessment.	Responsible **Requester / System Owner**
Step 02	**Risk Assessment** Information Security conducts an independent risk assessment of the proposed exception using the 5×5 matrix in Section 4.1. The assessment considers: (1) the severity of the requirement being deviated from; (2) the adequacy of the proposed compensating controls; (3) the realism of the proposed remediation timeline; (4) the regulatory implication — does this deviation create a regulatory gap? Information Security may request additional information, revise the risk score upward if the compensating controls are inadequate, or identify the deviation as non-approvable per Section 5. For GxP exceptions: Compliance / QA reviews the risk assessment and confirms whether the deviation creates a validated state impact requiring VMF documentation.	Responsible **Information Security / Compliance / QA (GxP)**
Step 03	**Approval** The exception is submitted to the approval authority per Section 4.2. Approval requires: (1) the approver(s) are satisfied the compensating controls reduce residual risk to an acceptable level; (2) the remediation plan is credible and has an executive sponsor; (3) the exception duration is the minimum necessary — not the maximum permitted; (4) the ISSG and Board notification requirements per Section 4.2 are confirmed. Approval must be in writing (email, system workflow, or signed exception record). Verbal approval is not valid. Conditional approval — 'approved provided compensating control X is implemented by date Y' — is permitted and conditions must be tracked.	Responsible **Approval Authority per Section 4.2**
Step 04	**Register Entry and Compensating Control Implementation** On approval: the exception is entered in the Exception Register (Section	Responsible **Information Security /**

	10) within 2 business days. The entry records all fields in the Register template. The compensating controls committed to in the exception request must be implemented before the exception is treated as active. Information Security confirms implementation. If compensating controls cannot be implemented within 10 business days of approval, the exception is suspended and the deviation treated as open non-compliance pending re-approval.	**Requester**
Step 05	**Ongoing Monitoring and Review** Each open exception is reviewed at the ISSG quarterly meeting. The review confirms: (1) the compensating controls remain in place and effective; (2) the remediation plan is on track; (3) the exception duration has not expired. For exceptions with a duration of 6 months or more: the Requester provides a written progress update on the remediation plan 30 days before the exception expiry date.	Responsible **Information Security / Requester / ISSG**
Step 06	**Renewal or Closure** At expiry: the exception is either closed (compliance achieved) or renewed. Renewal requires a fresh risk assessment and re-approval at the same or higher authority level as the original. A renewal that does not demonstrate meaningful progress toward the remediation goal will not be approved — the ongoing inability to meet a policy requirement without progress is a systemic risk management failure, not an exception condition. Closure: when the underlying non-compliance is remediated and the policy requirement is fully met, the Requester notifies Information Security. Information Security confirms compliance and closes the Register entry. The closed entry is retained in the Register for audit purposes.	Responsible **Requester / Information Security / Approval Authority**

7. Compensating Controls

Compensating controls are the alternative or supplementary measures that reduce the risk created by the policy deviation for the duration of the exception. They are not optional additions to an exception request — they are the primary basis on which the approval authority assesses whether the residual risk is acceptable.

Deviation Type	Compensating Control Examples
System unable to meet audit trail immutability requirement (non-GxP only — GxP version is non-approvable)	Export audit trail records to an external immutable store at least daily; implement cryptographic hash verification on log exports; restrict system audit trail configuration to a named two-person process with CISO approval for any change; increase monitoring frequency to detect anomalies; accept no changes to the system other than via the most restrictive change process.
System unable to enforce MFA	Compensate with network-level controls restricting access to known IP ranges only; implement enhanced monitoring for authentication events; reduce access provisioning to the absolute minimum required; require manual access review monthly rather than quarterly; implement privileged access management overlay (PAM) for all accounts even if the system itself does not natively support it.
GxP system validation overdue (e.g., major version upgrade requiring re-qualification not yet complete)	Continue to operate the system at the last validated version pending re-qualification; restrict all changes to emergency only under POL-007; increase audit trail review frequency to weekly; document the gap in the VMF; Compliance / QA confirms no GxP activities that depend on the new functionality proceed until re-qualification is complete.
Vendor access not yet fully assessed (Tier A vendor, assessment in progress)	Restrict vendor access to the minimum scope required for the activity; supervise all vendor sessions in real-time; revoke access immediately after each session (JIT access model); Information Security monitors all vendor sessions in SIEM; access limited to non-production or non-GxP systems until assessment is complete.
Data retention period cannot be met (e.g., technical limitation preventing deletion)	Place a data access restriction on the over-retained data immediately; document and justify the over-retention; notify DPO for GDPR assessment; implement delete capability as part of the remediation plan with a specific target date.
RTO/RPO target cannot currently be met for a Tier 1 system	Implement manual workaround procedures for the system's critical functions; increase the frequency of backup verification tests; ensure operations team is trained on manual procedures; notify key stakeholders of the current DR capability gap; implement enhanced monitoring to reduce detection-to-response time.

8. Reporting and Governance

Report	Audience	Frequency	Content
Exception Register summary	ISSG	Quarterly (at each ISSG meeting)	Number of open exceptions by category and risk level; new exceptions since last meeting; exceptions due for renewal; exceptions where remediation is behind plan; closed exceptions.
High / Critical exception notification	CISO, CIO, CEO (Critical)	Within 2–5 business days of approval per Section 4.2	Exception ID, policy domain, risk score, compensating controls, remediation plan, approval authority.
GxP exception notification	Compliance / QA Director, DIO, ISSG	Within 5 business days of any GxP-category exception approval	Exception details, VMF reference, assessment of validated state impact, regulatory notification assessment.
Board exception report	Board / Audit Committee	Annually, or immediately for Critical exceptions	Open Critical and High exceptions; exceptions open > 12 months; exceptions where remediation has not progressed; trend analysis.
Regulatory notification assessment	DPO / Compliance / QA / Legal	On approval of any exception implicating GDPR, HIPAA, or GxP regulatory obligations	Assessment of whether the exception creates a regulatory notification obligation; conclusion and rationale.

9. Roles and Responsibilities

Role	Responsibility
CISO	Policy owner. Approves Medium and above exceptions. Ensures exception register is maintained. Presents exception summary to ISSG. Escalates Critical exceptions to CEO and Board.
Information Security	Administers the exception process. Conducts risk assessments. Maintains the Exception Register. Monitors open exceptions. Reviews compensating control implementation. Alerts CISO to overdue renewals or remediation slippage.
Compliance / QA	Mandatory reviewer for all GxP-category exceptions. Assesses validated state impact. Confirms VMF documentation requirement. Assesses regulatory notification for GxP exceptions.
DPO	Mandatory reviewer for all privacy-category exceptions and any exception affecting personal data processing. Assesses GDPR supervisory authority

Role	Responsibility
	notification obligation for exceptions creating regulatory gaps.
CIO	Co-approver for High and Critical exceptions. Accountable for remediating infrastructure and operational exceptions within the committed timelines.
CEO	Co-approver for Critical exceptions. Informed of all Board-notifiable exceptions.
Requester / System Owner	Submits the exception request. Implements and maintains compensating controls. Owns the remediation plan. Provides progress updates on request and before renewal.
ISSG	Reviews exception register summary quarterly. Challenges exceptions where compensating controls appear inadequate or remediation is not progressing. Recommends escalation to Board where appropriate.

10. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Parent framework — EXC-001 is the cross-cutting exception governance mechanism for all IMF-issued documents
RACI-001	Roles, Responsibilities and Authorities	Accountability for exception management governance
REG-001	IMF Document Register	Exception register is tracked in EXC-001; the register of all IMF documents is maintained in REG-001
POL-001	Data Classification Policy	Data classification exception process references this document; exception sections in each policy are governed by EXC-001
POL-002	Data Retention and Disposal Policy	Retention period exceptions require DPO and Legal review; statutory retention obligations may make certain retention exceptions non-approvable
POL-003	Data Integrity Policy	GxP data integrity exceptions are Category 2 (most restricted approvable category); exceptions to ALCOA+ attributable and complete requirements for GxP systems are non-approvable per Section 5
POL-004	Privacy Policy	Privacy exceptions require mandatory DPO involvement; processing without a legal basis is non-approvable; GDPR supervisory authority notification assessment required for approved exceptions
POL-005	System Classification Policy	System classification exceptions affect downstream risk tier and control requirements across multiple policies
POL-006	Computer System Validation and Qualification Policy	GxP system validation exceptions require VMF documentation; operating an unvalidated GxP system is non-approvable
POL-007	Change Management Policy	Change management exceptions have a 3-month maximum duration; exceptions enabling uncontrolled GxP changes are non-approvable
POL-008	Access Control Policy	Access control exceptions limited to 3 months; shared accounts on GxP systems are non-approvable
POL-009	Privileged Access Management Policy	Privileged access exceptions are high-risk; exception to PAM session recording for Tier 1/GxP systems requires CISO approval

Document ID	Title	Relationship
POL-010	Information Security Risk Policy	Risk acceptance under POL-010 for residual risks is distinct from an exception; the exception risk scoring matrix is identical to enable direct comparison; High/Critical exceptions feed the IS Risk Register
POL-011	Business Continuity Policy	RTO/RPO exceptions require enhanced manual workaround procedures as compensating controls
POL-012	Incident Response Policy	Exceptions to incident notification SLAs affecting regulatory breach notification require Board awareness
POL-013	Third Party and Vendor Risk Policy	Vendor engagement before full assessment exceptions are high-risk; require CISO approval and real-time session supervision as compensating controls
POL-014	Audit Trail and Monitoring Policy	Most restricted exception category; audit trail immutability and the ability to disable audit trails on GxP systems are non-approvable; any approved exception requires immediate ISSG notification
POL-015	IT Service Management and Operational Incident Policy	Operational incident response exceptions governed under this policy

11. Exception Register

The Exception Register is the authoritative record of all active and recently closed exceptions to IMF policy requirements. It is maintained by Information Security and reviewed at each ISSG quarterly meeting. All fields are mandatory. Entries are numbered sequentially: EXC-001-001, EXC-001-002, etc.

IMPORTANT: The Exception Register is a controlled document. Entries must be made and updated only by Information Security or the designated exception administrator. Unauthorised modifications to the register are a governance failure and a potential data integrity incident under POL-003 / POL-012. The register is retained for 7 years from the date each entry is closed.

11.1 Register Field Definitions

Field	Description
Exception ID	Sequential unique identifier: EXC-001-[NNN]
Status	Open (Active) | Open (Pending Compensating Controls) | Open (Renewal Pending) | Closed
Policy Reference	Document ID and Section of the specific requirement being deviated from (e.g., 'POL-008 §4.3 — MFA requirement')
Category	Exception category per Section 3 of this policy
System / Process	The specific system(s) or process(es) affected by the exception
Regulatory Flags	GxP / SOX / GDPR / HIPAA — flags from the affected system's POL-005 classification
Deviation Description	Precise description of what requirement is not being met and why
Risk Score	Likelihood × Impact using Section 4.1 matrix. Format: L[n] × I[n] = [score] ([level])
Compensating Controls	Description of each compensating control, implementation date, and verification method
Remediation Plan	Specific steps to achieve full compliance, with target dates and named owner for each step
Requester	Name and role of the individual who submitted the exception request
Approval Authority	Named individuals who approved the exception, with dates of approval
VMF Reference	VMF entry reference for GxP exceptions (or 'N/A')
Approved Date	Date formal approval was granted
Expiry Date	Date the exception expires — maximum per category in Section 3
ISSG Notified	Date ISSG was notified (or 'N/A' for Low-risk exceptions not requiring notification)

Field	Description
Board Notified	Date Board was notified (or 'N/A' where not required)
Last Review Date	Date of the most recent ISSG review of this exception
Closed Date	Date the exception was closed, and closing reason (compliance achieved / not renewed / superseded)
Closure Confirmed By	Name and role of the Information Security reviewer who confirmed compliance on closure

11.2 Active Exception Register

No exceptions are currently recorded. This register is populated as exceptions are approved. The register is presented at each ISSG meeting in summarised and full-detail form.

Exception ID	Policy Ref	Category	System / Process	Risk Score	Status	Expiry Date
—	—	—	—	—	No active exceptions at document issue	—

11.3 Closed Exception Register

Closed exceptions are retained below for audit purposes. Retention period: 7 years from closure date.

Exception ID	Policy Ref	Category	System / Process	Approved Date	Closed Date	Closing R
—	—	—	—	—	No closed exceptions at document issue	—

12. Definitions

Term	Definition
Compensating Control	An alternative or supplementary security or compliance measure that reduces the risk created by a policy deviation for the duration of an approved exception.
Exception	A formal, time-bounded, risk-assessed, and approved deviation from a

Term	Definition
	mandatory requirement of an IMF-governed document.
Non-Approvable Deviation	A deviation from a mandatory requirement that cannot be approved as an exception because it would create an irreducible regulatory non-compliance regardless of compensating controls. See Section 5.
Non-Compliance	An unapproved deviation from a mandatory IMF policy requirement. Non-compliance is a disciplinary matter and must be remediated immediately.
Remediation Plan	The documented steps and timeline by which the Requester commits to achieving full compliance with the requirement from which the exception was granted.
Requester	The System Owner, process owner, or team lead responsible for the area where the deviation exists and who submits the exception request.
Residual Risk	The risk that remains after compensating controls have been applied to an approved exception.

— End of Document —

EXC-001 v1.0 DRAFT | [Company Name] | CONFIDENTIAL